

AI-Powered Social Engineering Defence Guide

How AI-generated phishing, voice cloning, and deepfake video calls are being weaponised against businesses — and what you can do about it.

1,760%

increase in AI-driven
BEC attacks since 2022
Hoxhunt 2025

60%

of recipients fall for
AI-generated phishing
StrongestLayer 2026

\$40B

projected deepfake
fraud losses by 2027
DeepStrike

WEHACK

We hack you before they do.

Social Engineering Has Been Weaponised by AI

In 2024, social engineering was already the #1 attack vector. In 2025-2026, generative AI has industrialised it. Attacks that once took days of manual research now take seconds. The quality is indistinguishable from legitimate communication.

80%+

of phishing emails now
AI-generated
StrongestLayer 2025

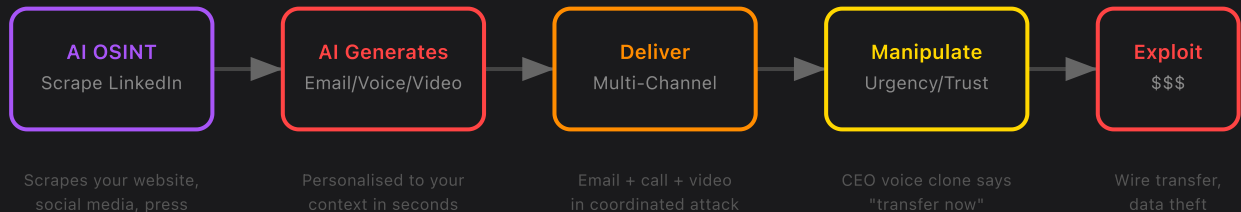
4x

higher click-through for
AI-crafted phishing
Programs.com

89%

increase in AI-enabled
attacks YoY
CrowdStrike 2026 GTR

THE AI SOCIAL ENGINEERING KILL CHAIN



- **BEC now makes up 50%+ of all social engineering incidents.** Organisations with fewer than 1,000 employees have a 70% weekly probability of experiencing at least one BEC attack. [Hoxhunt 2025](#)
- **Average BEC wire transfer request: \$24,586.** FBI IC3 logged \$2.7 billion in BEC losses in 2024 alone — and that's only what was reported. [FBI IC3 2024](#)
- **73% of organisations affected by cyber-enabled fraud in 2025.** AI has made social engineering profitable at industrial scale. [WEF Global Cybersecurity Outlook 2026](#)
- **AI scams surged 1,210% in 2025** — growing 6x faster than traditional fraud. The tools are free, the barrier to entry is zero, and the quality is expert-level. [Vectra AI](#)

The 5 AI-Powered Attacks Targeting Your Business

Each of these is being actively used against NZ businesses right now. Understanding them is the first step to defending against them.



1. AI-Generated Phishing Emails

CRITICAL THREAT

AI generates grammatically perfect, contextually aware phishing emails at scale. Gone are the obvious "Dear Sir/Madam" scams with spelling errors. Modern AI phishing references your recent projects, uses your company's tone of voice, and targets specific employees with personalised pretexts. By early 2025, 80%+ of phishing emails were AI-generated.

Click-through rate: 54% for AI phishing vs 12% for traditional — StrongestLayer 2025



2. Voice Cloning & Vishing

HIGH THREAT

3 seconds of audio is all it takes to clone a voice at 85% accuracy. Attackers scrape CEO interviews, conference talks, or voicemail greetings, then generate convincing voice calls. 680% increase in voice cloning fraud year-over-year. 400 companies per day are targeted by CEO deepfake voice fraud. 77% of voice clone victims suffered financial loss. A Swiss businessman lost several million francs to a cloned business partner voice in January 2026.

DeepStrike 2025, Vectra AI 2026



3. Deepfake Video Calls

GROWING THREAT

Real-time deepfake video impersonation on Zoom/Teams calls. The \$25 million Arup Corporation loss came from a deepfake video call where every participant except the victim was fake. 700% surge in deepfake video scams in 2025. Only 24.5% of humans can reliably identify high-quality deepfake video. 80% of companies have no deepfake response protocols.

Brightside AI, ScamWatch HQ 2025, DeepStrike



4. AI-Powered Pretexting & OSINT

HIGH THREAT

AI agents scrape LinkedIn, company websites, press releases, and social media to build detailed profiles of targets. They identify reporting structures, recent projects, upcoming events, and communication patterns — then craft attack scenarios that perfectly match the target's context. What used to take a human attacker days of research takes AI minutes.



5. Multi-Channel Coordinated Attacks

EMERGING THREAT

The most sophisticated attacks combine multiple vectors: an AI-generated email referencing a real invoice, followed by a voice-cloned phone call from the "CEO" to add urgency, potentially even a deepfake video call for confirmation. Each layer reinforces the others. When the same persona appears across email, phone, and video, human suspicion drops dramatically.

87% of attacks span multiple surfaces — Unit 42 2026

Real-World Attack Scenarios

These aren't hypothetical. Every scenario below has been observed in the wild in 2025-2026. Any one of them could target your business tomorrow.

SCENARIO 1: THE URGENT WIRE TRANSFER

Your CFO receives an email from the CEO about an urgent, confidential acquisition that requires an immediate wire transfer. The email is perfectly written, references a board meeting from last week, and is followed 10 minutes later by a phone call — in the CEO's cloned voice — confirming the request.

"Hey Sarah, it's Mark. Listen, did you get my email about the Meridian deal? The lawyers need the deposit by 3pm or we lose the bid. Can you process the \$47,000 transfer? I've sent the details. I'm heading into another meeting — just let me know when it's done."

Why it works: Email + voice creates dual-channel confirmation. The urgency prevents verification. The reference to a real meeting (scraped from LinkedIn) adds credibility. Average loss: \$24,586 per BEC attempt.

SCENARIO 2: THE FAKE VIDEO CALL

A finance team member is invited to a Zoom call with the "Regional Director" and "External Auditor" to discuss an emergency audit finding. Both participants are deepfakes. They instruct the employee to transfer funds to a "secure holding account" while the audit is resolved. The Arup Corporation lost \$25M to this exact pattern.

Why it works: Multiple authority figures on camera. Real-time interaction feels authentic. Urgency + authority + secrecy = perfect manipulation.

SCENARIO 3: THE VENDOR INVOICE REDIRECT

Your accounts payable team receives an email from a regular supplier — identical formatting, correct reference numbers, same contact name — with "updated banking details." The email is actually an AI-generated perfect copy, sent from a typosquatted domain (e.g., supp1ier.co.nz instead of supplier.co.nz).

Why it works: References real purchase orders (scraped from compromised email). Uses identical branding. The domain change is near-invisible. NZ businesses lose millions annually to payment redirection fraud.

SCENARIO 4: THE IT SUPPORT CALLBACK

An employee receives an email about a "security alert" on their M365 account, followed by a phone call from "IT Support" using a cloned voice of your actual IT manager. They're guided through resetting their password — to one the attacker controls. The 563% increase in fake CAPTCHA lures feeds exactly into this pattern.

Why it works: Combines phishing anxiety with familiar voice. The employee thinks they're fixing a problem. The attacker gets live M365 credentials.

The NZ Context

NZ's relatively high-trust business culture makes social engineering especially effective. We default to trusting people we "know." Add AI-generated voice and video that sounds exactly like someone we

know, and our natural defences are bypassed. The 26,000 New Zealanders affected by Lumma Stealer credential theft mean there's already a pool of compromised NZ business credentials being traded on dark web markets.

The 8-Step Defence Framework

Technical controls aren't enough — social engineering targets humans. You need to change how your organisation makes decisions, verifies requests, and responds to pressure.

1

Implement a Verification Protocol for Financial Requests

Any wire transfer, payment change, or financial instruction over a threshold (e.g., \$1,000) requires verification via a pre-agreed second channel. If the request came by email → verify by phone (using a known number, NOT a number in the email). If it came by phone → verify by a separate call back to a known number. Never verify through the same channel the request arrived on.

2

Create a "Codeword" System for Sensitive Requests

Establish rotating codewords that must be used for authorisation of high-value transactions, account changes, or credential resets. A voice clone can replicate how someone sounds — but it can't know a codeword that was shared in person. Change codewords monthly. Keep them off any digital system.

3

Train Staff on AI-Specific Red Flags

Traditional phishing training is outdated. Staff need to recognise: unusual urgency combined with secrecy ("don't tell anyone about this yet"), requests that bypass normal approval processes, any request for payment detail changes via email only, and video calls where participants seem slightly "off" (lighting, lip sync, eye contact). Security awareness training reduces phishing success by 86% after 1 year.

4

Enforce Dual-Authorisation for All Payments

No single person should be able to authorise or execute payments above a defined threshold. Require two-person sign-off with mandatory cooling-off period (even 30 minutes breaks the urgency manipulation). This one control alone would prevent the majority of BEC losses.

5

Harden Your Digital Footprint

AI-powered attacks start with reconnaissance. Reduce what attackers can learn: limit employee personal details on LinkedIn (job title is fine — reporting structure and project details feed attacks), review what your website reveals (team photos, bios, org charts), and check that ex-employee accounts are disabled immediately. The less data available, the harder it is to craft a convincing attack.

6

Deploy AI-Aware Email Security

Traditional email filters catch known threats. AI-generated phishing is unique each time — it evades signature-based detection. Deploy email security that uses AI/ML to analyse writing style, sender

behaviour, and content anomalies. Configure M365 Defender with anti-phishing, Safe Links, and impersonation protection (see our M365 Hardening Guide).

7

Establish a "Report Without Blame" Culture

95% of breaches involve human error. If employees fear punishment for clicking a link or falling for a scam, they'll hide it — giving attackers more time. Create a no-blame reporting channel. Celebrate catches. Run simulated phishing tests to normalise the reporting process. The faster someone reports a suspicious interaction, the less damage occurs.

8

Test Your Defences with Social Engineering Assessments

The only way to know if your training and processes actually work is to test them. Professional social engineering assessments use the same AI tools and techniques that attackers use — phishing simulations, vishing calls, pretexting scenarios — in a controlled, authorised engagement. Find your weak spots before attackers do.

The Verification Protocol

Print this and give it to every employee who handles finances, credentials, or sensitive data. When in doubt — verify.

Before Approving Any Financial Request



STOP — Don't Act Under Pressure

If someone says "this is urgent" or "don't discuss this with anyone" — that's the red flag. Real emergencies allow 30 minutes of verification.



VERIFY — Call a Known Number

Call the requester back on a phone number you already have (from your contacts, not from the email or message). If it was your CEO — call their mobile. If it was a supplier — call the number on your original contract, not the one in the email.



CONFIRM — Use the Codeword

Ask for the current verification codeword. A voice clone can sound like your CEO but cannot know this week's codeword. If they can't provide it, treat it as suspicious.



AUTHORISE — Get Second Sign-Off

No single person approves payments above your threshold. Walk to a colleague's desk. Send a separate message. Get eyes on the request from someone who wasn't part of the original communication chain.



DOCUMENT — Log Everything

Record the request details, who verified, and when. If it turns out to be legitimate — great, you have a paper trail. If it was an attack — you have evidence for insurers, police, and the Privacy Commissioner.

\$2.7B

BEC losses reported to
FBI IC3 in 2024

FBI IC3

70%

can't distinguish real
voice from AI clone

DeepStrike

86%

reduction in phishing
after training

Cobalt

AI Detection Tips for Video Calls

- Ask the person to turn their head sideways or wave their hand in front of their face — current deepfakes struggle with occlusion
- Watch for micro-delays between lip movement and audio — even slight desync is unnatural

Inside the Attacker's AI Toolchain (2026)

Understanding what tools attackers actually use helps you build better defences. This isn't theoretical — these are the tools and techniques we see in active campaigns and simulate in our penetration tests.

The Phishing Kit: Tycoon 2FA / EvilProxy / Evilginx

These are reverse-proxy phishing frameworks that sit between the victim and the real Microsoft 365 login page. The victim sees a pixel-perfect copy of the real login, enters their credentials AND completes MFA — the proxy captures the session token post-authentication. The Tycoon phishing kit was the primary tool behind the December 2025 campaign that compromised 3,000+ M365 accounts across 900 organisations. These kits cost \$200-400/month on criminal forums and require zero coding skill to deploy.

Defence: Phishing-resistant MFA (FIDO2 keys), Conditional Access token binding, Continuous Access Evaluation (CAE)

Voice Cloning: ElevenLabs / RVC / So-VITS

Commercial voice cloning services can create a convincing voice clone from as little as 3 seconds of audio. Open-source alternatives (RVC, So-VITS) run locally and leave no cloud traces. Attackers scrape CEO interviews from YouTube, conference recordings, or even company voicemail greetings. The quality is now indistinguishable from real speech in 70% of cases. Real-time voice conversion allows live phone conversations in a cloned voice — the attacker speaks naturally and the AI converts their voice to the target's in real-time with ~200ms latency.

Defence: Codeword systems, callback verification to known numbers, never trust voice alone for authorisation

Deepfake Video: DeepFaceLive / FaceFusion / SimSwap

Real-time face-swapping tools can run a deepfake during a live Zoom/Teams call. The attacker's webcam feed is replaced by a generated face that matches the target's appearance and moves in real-time. Current generation tools achieve 90%+ accuracy with good lighting. The \$25M Arup loss used this technology — every participant on the call except the victim was a deepfake. 159,378 unique deepfake scam instances were detected in Q4 2025 alone (Gen Threat Labs).

Defence: Occlusion tests (hand in front of face), unexpected actions, side-profile requests, out-of-band verification

AI OSINT: GPT-Researcher / Perplexity / Custom Agents

AI research agents can compile a comprehensive target profile in minutes. They cross-reference LinkedIn, company websites, press releases, court records, Companies Office filings, and social

media. They identify reporting structures, recent deals, communication styles, and personal interests. An attacker's AI agent can generate 50 personalised phishing emails in the time it takes a human to write one — each tailored to the recipient's role, recent activity, and communication preferences.

Defence: Reduce digital footprint, limit LinkedIn detail, review what's publicly accessible about your organisation

The Multi-Modal Attack Stack

The most sophisticated campaigns combine all of the above: AI OSINT builds the target profile → AI generates a contextually perfect phishing email → voice clone follows up by phone → deepfake video call for "confirmation." Each layer reinforces the others. The entire attack can be orchestrated by a single person using commercially available tools for under \$1,000/month. This is why traditional security awareness training (built around grammar errors and suspicious domains) is no longer sufficient.

Why AI Social Engineering Works So Well

Understanding the psychological principles being exploited is the deepest layer of defence. AI doesn't just automate attacks — it weaponises cognitive biases at scale.



Urgency Exploitation

AI-generated messages create time pressure that triggers the amygdala (fight-or-flight), bypassing the prefrontal cortex (rational analysis). When your "CEO" calls at 4:50pm on a Friday saying a transfer needs to happen before close of business, your brain prioritises compliance over verification. AI can identify the optimal timing for each target based on their calendar, timezone, and communication patterns.



Authority Amplification

Milgram's obedience experiments showed that 65% of people will follow authority figures even against their better judgment. AI supercharges this by replicating the exact voice, face, and communication style of authority figures. When the request comes from someone who looks, sounds, and writes exactly like your CEO — your brain's authority compliance circuits override your suspicion circuits. This is exponentially more effective than a text-only email.



Trust Network Poisoning

AI builds rapport by referencing real shared experiences, recent events, and personal details scraped from social media. It creates a sense of existing relationship. When combined with voice cloning, the victim's brain activates recognition pathways — "I know this person, I trust this person." NZ's high-trust business culture is particularly vulnerable. We default to assuming good intent, especially with people we "recognise."



Cognitive Load Overload

Multi-channel attacks (email + call + video) overwhelm the brain's ability to critically evaluate each interaction. When you're processing visual input (deepfake video), audio input (cloned voice), and a complex request simultaneously, your capacity for suspicion drops dramatically. AI deliberately uses this — adding technical jargon, multiple reference numbers, and time pressure to maximise cognitive load and minimise critical thinking.

65%

obey authority figures
against better judgment

Milgram, replicated 2023

95%

of breaches involve
human error

Cobalt

86%

phishing reduction
after awareness training

Cobalt

The Counter-Intuitive Defence

The most effective defence against AI social engineering isn't technology — it's **process**. Technology detects threats; process prevents exploitation. A simple rule like "no wire transfer over \$5,000 without two-person authorisation and callback verification" would prevent the majority of BEC losses. The Arup \$25M loss could have been prevented by one phone call to a known number. Build processes that assume compromise and require verification, regardless of how "legitimate" a request appears.

WHAT'S NEXT

Test Before They Attack

The only way to know if your people will fall for AI-powered social engineering is to test them — ethically, professionally, and before real attackers do.

Social Engineering Assessment

We simulate AI-generated phishing, vishing (voice cloning), and pretexting attacks against your team in a controlled, authorised engagement. You get a detailed report showing who was vulnerable, what worked, and exactly how to fix it.

Take Your Free Security Score →

Every business has different security challenges. Book a free 15-minute chat and we'll recommend the right approach — no obligation.

Mustafa Demirsoy
Founder & Hacker, WeHack

wehack.co.nz | info@wehack.co.nz | 022 091 7242
148 Durham Street, Tauranga 3110